

03-SUSPICIOUS-PROCESS-EXECUTION

Suspicious Process Execution Detection (auditd monitoring)

Detection Scenario

This lab documents the implementation of advanced process auditing at the Linux kernel level using auditd and the subsequent ingestion of its telemetry into Splunk Enterprise. The scenario simulates a post-compromise environment where an attacker executes system tools and utilities (such as network downloaders or information gathering commands) commonly associated with Command and Control (C2) communications or payload deployment.

Objective

Obtain deep visibility into endpoint process creation, monitor system call telemetry (execve), and detect the execution of suspicious binaries and arguments on Linux endpoints.

Environment

- **Victim Server:** Ubuntu Server (with process auditing enabled)
- **SIEM Platform:** Splunk Enterprise
- **Auditing Daemon:** auditd
- **Log Shipper:** Splunk Universal Forwarder

Auditd Configuration & Architecture

Install Audit

Instalación del demonio de auditoría en el servidor víctima:

```
sudo apt update
sudo apt install auditd -y
```

Enable Service

Habilitación e inicio continuo del servicio para asegurar la persistencia de la recolección:

```
sudo systemctl enable auditd
sudo systemctl start auditd
```

Configure execve Auditing (System Call Tracking)

Configuración de la regla de auditoría en tiempo real para capturar de forma mandatoria la ejecución de cualquier binario a través de la llamada al sistema execve (arquitectura de 64 bits):

```
sudo auditctl -a always,exit -F arch=b64 -S execve
```

Data Source

Log File	/var/log/audit/audit.log
Index	Main
Sourcetype	Linux_audit

Detection Logic & SPL Queries

1. Base Process Execution Events

Query inicial utilizada para listar cronológicamente todos los eventos donde el kernel de Linux registró una llamada de ejecución de procesos:

```
index=main sourcetype=linux_audit type=EXECVE
```

2. Process Argument Reconstruction (Visibilidad de Comandos Completos)

Query avanzada para mapear y reconstruir los argumentos secuenciales (a0, a1, a2, a3) que componen el comando ejecutado por el usuario o script, renombrando las columnas para una lectura formal en un panel SOC:

```
index=main sourcetype=linux_audit type=EXECVE ("curl" OR "wget")
| table _time host a0 a1 a2 a3
| rename a0 as "Binary/Command", a1 as "Argument 1", a2 as "Argument 2", a3 as "Argument 3"
```

3. Suspicious Network Tool Execution (Detección de curl / wget)

Filtro táctico de Threat Hunting diseñado para interceptar inmediatamente el uso de utilidades de red nativas empleadas por atacantes para descargar malware o exfiltrar datos:

```
index=main sourcetype=linux_audit type=EXECVE ("curl" OR "wget")
| table _time host a0 a1 a2 a3
```

4. Basic SOC Telemetry Correlation (Correlación básica multiclase)

Consulta de correlación que unifica las fuentes de datos de autenticación tradicional y las llamadas de auditoría del kernel para mapear la transición completa del atacante:

```
index=main (sourcetype="Ubuntu-Victima" OR sourcetype="linux_audit") ("Accepted password" OR "sudo" OR "curl" OR "wget")
| table _time host sourcetype _raw
```

Analysis

The implemented kernel-level auditing bypasses standard application log limitations by recording executions directly from the system call interface (execve). Telemetry analysis successfully flagged activities involving network tools (curl/wget). Because auditd captures the exact system arguments chronologically, analysts can definitively isolate remote staging domains or malicious script parameters, distinguishing legitimate administrative activities from post-exploitation actions.

Findings

- **Granular Process Visibility:** Confirmed successful capture of low-level process parameters across the system.
- **Command Argument Resolution:** Complete operational arguments (such as destination URLs or specific command flags) were fully exposed inside Splunk.
- **Suspicious Network Activities:** Identified distinct patterns of manual/automated downloads targeting external IPs or domains.
- **Multi-Source Correlation:** Validated the ability to trace a chronological attack path from a user login down to subsequent command line payloads.

MITRE ATT&CK Mapping

- **Tactic:** Execution
- **Technique:** T1059 — Command and Scripting Interpreter

Impact

Unmonitored process execution can permit undetected execution of malicious binaries, lateral movement scripts, or toolkits, allowing attackers to establish persistence, download secondary implants, or exfiltrate environment files.

Classification

True Positive (Controlled laboratory simulation of post-exploitation tooling execution).

Recommendations

1. Establish application allowlisting policies or restrict the execution of binaries like curl, wget, nc, or compiler tools for non-privileged system users.
2. Configure automated alerts in Splunk for any type=EXECVE event containing internet-facing arguments or unexpected external connections.
3. Keep persistent auditd rules configured in /etc/audit/rules.d/audit.rules to prevent settings from being wiped during server reboots.
4. Implement continuous correlation models between network flow telemetry and system call logs to quickly validate C2 activities.